CASE STUDY

The European Commission Cloud Breach of 2026: AWS Data Theft Through the Poisoned Trivy Scanner

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

Trivy is an open-source security scanner that many teams run inside their build pipelines to look for vulnerable packages and misconfigurations before code ships. In March 2026 that habit became the way in. On 19 March someone used compromised credentials to publish a malicious Trivy release and to repoint almost every tag of the project's two GitHub Actions at credential-stealing code. Pipelines that pulled the affected versions or tags during the exposure windows ran an infostealer with access to the secrets those pipelines held.

One of those pipelines belonged to the European Commission. The Commission and CERT-EU, the cybersecurity service for the EU institutions, assess with high confidence that the Trivy compromise was the initial access vector: the Commission had received a compromised Trivy through normal update channels, and the attacker obtained a Commission AWS secret on 19 March, the day of the compromise. That key carried management rights over other Commission AWS accounts. The attacker searched for more secrets, added a fresh access key to an existing user, and took data from the cloud backend of the europa.eu web hosting service. The Commission's security operations centre saw the anomalies five days later, on 24 March. On 28 March the data extortion group ShinyHunters published about 91.7 GB compressed (340 GB uncompressed) on its leak site. The data touch up to 71 hosting clients: 42 internal Commission clients and at least 29 other Union entities.

The case matters because, among the government sources opened for this study (CERT-EU, the FBI and the AFP), it is the only downstream victim with a published post-incident report (**Inferred**). It shows the whole chain in a single record: an open-source tool, a pipeline secret, a cloud key with management rights over other

accounts, five days of undetected access, and a public leak.

> Evidence grade: the Trivy compromise, the CVE and KEV records, the Commission's statements, and CERT-EU's account of the intrusion are **Confirmed** from Aqua Security, NVD, CISA, the Commission and CERT-EU. Claims by the actors, data volumes from news outlets, and third-party research relayed by news are **Reported**. This study's own reasoning is labelled **Inferred**.

Key facts at a glance

Field	Value
Victim	European Commission, the AWS backend of the europa.eu web hosting service [1] [2]
Affected parties	Up to 71 hosting clients: 42 internal Commission clients and at least 29 other Union entities [1]
Initial access	Trivy supply-chain compromise, assessed by CERT-EU with high confidence [1]
Upstream identifier	CVE-2026-33634, GHSA-69fq-xp46-6x23, critical, CWE-506 Embedded Malicious Code [3] [4]
CVSS	9.4 Critical (CVSS 4.0, GitHub as CNA); 8.8 High (CVSS 3.1, NVD's own score) [4]
CISA KEV	Added 26 March 2026, due 9 April 2026, known ransomware campaign use: Unknown [5]
Key obtained	19 March 2026 [1]
Detected	24 March 2026, by Commission CSOC alerts on Amazon API misuse and abnormal traffic [1] [2]
CERT-EU notified	25 March 2026 [1]
Public statement	Press release IP/26/748, 27 March 2026 [2]
Data published	28 March 2026 by ShinyHunters: about 91.7 GB compressed, 340 GB uncompressed [1]
Lateral movement	None uncovered as of 2 April 2026; no website taken offline or altered [1]
Attribution	Trivy compromise attributed to TeamPCP by Aqua (plausible, not confirmed); CERT-EU makes no attribution of the AWS intrusion [1] [6]

Key findings

- **The entry point was a security tool.** CERT-EU bases its high-confidence assessment on the timing match on 19 March, the targeting of AWS credentials, and the Commission's use of a compromised Trivy version received through normal update channels [1] (**Confirmed**).
- **The upstream fix was incomplete.** Aqua disclosed a first Trivy incident on 1 March and rotated credentials, but the rotation was not atomic, so the attacker may have kept access through refreshed tokens [3] [7] (**Confirmed**). The 19 March attack was the continuation [3] [4] (**Confirmed** as Aqua's assessment).
- **One key reached too far.** The stolen AWS secret carried management rights over other Commission-affiliated AWS accounts. The attacker created a new access key and attached it to an existing user to evade detection [1] (**Confirmed**).

- **Detection worked, after five days.** The CSOC alerted on potential misuse of Amazon APIs, possible account compromise and abnormal network traffic on 24 March [1] (**Confirmed**). Access began on 19 March, so the dwell time was about five days (**Inferred**).
- **The leak and the intrusion are separate claims.** CERT-EU says ShinyHunters published the data; it does not say ShinyHunters carried out the intrusion and states no ShinyHunters link to TeamPCP [1] (**Confirmed**). News reports that ShinyHunters "claimed responsibility" [15] (**Reported**).
- **The confirmed data came mainly from Commission websites.** The set holds names, usernames and email addresses and at least 51,992 outbound email-related files (2.22 GB), mostly automated notifications [1] (**Confirmed**). The Commission says internal systems were not affected [2] (**Confirmed**).

Top recommendations

1. **Upgrade and rotate together.** Move to Trivy v0.69.2 or v0.69.3, trivy-action v0.35.0 and setup-trivy v0.2.6, and treat every secret reachable from a pipeline that ran an affected version as exposed [3] [4] (**Confirmed**).
2. **Pin Actions to full commit SHAs.** Tags were force-pushed, while images referenced by digest and releases protected by immutable releases were not affected; CERT-EU and the FBI both recommend full-SHA pinning [1] [3] [8] (**Confirmed**).
3. **Take long-lived cloud keys out of CI/CD.** Scope pipeline credentials to least privilege, add AWS service control policies, and prefer temporary credentials [1] [8] (**Confirmed**).
4. **Hunt in CloudTrail for the pattern CERT-EU describes.** Look for anomalous STS calls, TruffleHog activity and new access keys attached to existing users [1] (**Confirmed**).
5. **Search for the stealer's fallback.** Look for public repositories named `tpcp-docs` or `docs-tpcp` in your GitHub organizations [4] [8] (**Confirmed**).
6. **Plan for the long tail.** The FBI warns that affiliated actors are likely to use stolen data and credentials long after the initial compromise; CERT-EU advises watching for phishing that reuses the leaked personal data [1] [8] (**Confirmed**).
7. **Treat CI/CD tools as vendors.** CERT-EU also asks for signature checks, vendor risk management and behaviour monitoring for CI/CD tools, and for the ATT&CK mitigations M1043 Credential Access Protection, M1018 User Account Management, M1051 Update Software and M1016 Vulnerability Scanning [1] (**Confirmed**).

Scope and method

This brief covers the European Commission intrusion from the late-February compromise of Trivy's build environment to the FBI advisory and Australian charges of July and August 2026. It treats the wider TeamPCP campaign (Checkmarx KICS, LiteLLM, Telnyx and the Bitwarden CLI) only where it bears on attribution or defense: The TeamPCP Supply-Chain Campaign of 2026 is the home study for the campaign and the Trivy compromise, and this brief is the home study for the Commission intrusion. The Year 2026 in Intrusions indexes both among the year's events. It draws on CERT-EU's post-incident report, the Commission's press release, the Aqua Security advisory, blog and project discussion, the NVD and KEV records, the FBI FLASH and the Australian Federal Police release, Microsoft's detection guidance, the live ATT&CK group pages, the library's own ATT&CK, D3FEND, CWE and CAPEC data files, and press coverage graded Reported. Every source was opened on 11 November 2026. Tradecraft is described at advisory level; no command, payload or file hash is reproduced, and the one domain named is defanged.

Grade	Meaning
Confirmed	A primary source was opened: the victim, CERT-EU, a government agency, the vendor's advisory, a CVE, NVD or KEV record, or the MITRE record itself
Reported	Known only through a secondary source, such as news coverage, an actor's claim to a journalist, or third-party research relayed by another party
Demonstrated	A public reproduction exists. No item here is graded Demonstrated
Inferred	This study's own reasoning from the cited facts, labelled where it appears

Attribution is carried exactly as each source states it. Where Aqua calls TeamPCP's role "plausible", this study does not upgrade it, and where CERT-EU declines to attribute, this study does not attribute for it. The August 2026 Australian charges are allegations, not convictions, and the release does not name the accused; neither does this study.

Part 1: what happened

All times are UTC where a source gives them.

Date (2026)	Event	Source	Grade
Late Feb	Attackers exploit a misconfiguration in Trivy's GitHub Actions environment and extract a privileged access token	[6]	Confirmed
Feb	The library's AI Threats 2026 study records an automated account, hackerbot-claw, stealing a Trivy token in February; Aqua's own records do not name it	[19]	Reported (as graded there)
1 Mar	The Trivy team discloses the first incident and rotates credentials; the rotation is not atomic	[3] [4]	Confirmed
3 Mar	GitHub immutable releases enabled on trivy, before v0.69.3	[3]	Confirmed
4 Mar	Immutable releases enabled on trivy-action, before 0.35.0	[3]	Confirmed

Date (2026)	Event	Source	Grade
19 Mar, about 17:43	Malicious Trivy v0.69.4 tag pushed; 76 of 77 trivy-action tags force-pushed and all 7 setup-trivy tags replaced with credential-stealing commits	[3]	Confirmed
19 Mar, 18:22 to about 21:42	Trivy v0.69.4 live on GitHub, deb, rpm, GHCR, ECR Public, Docker Hub and get.trivy.dev; setup-trivy exposed until about 21:44	[3]	Confirmed
19 Mar	Attacker obtains a Commission AWS secret through the Trivy compromise, runs TruffleHog to find and validate further secrets through STS, and begins reconnaissance; it later attaches a new access key to an existing user (date not given)	[1]	Confirmed
20 Mar, about 05:40	trivy-action exposure window closes	[3]	Confirmed
20 Mar	Trivy discussion #10425 opened: a follow-up to the 1 March incident, first containment incomplete, malicious artifacts removed	[7]	Confirmed
21 Mar	GHSA-69fq-xp46-6x23 published (CVE-2026-33634, critical, CWE-506)	[3]	Confirmed
22 Mar, 15:43, to 23 Mar, about 01:40	Malicious Docker Hub images aquasec/trivy 0.69.5 and 0.69.6 live, pushed with separately compromised Docker Hub credentials	[3]	Confirmed
23 Mar	Wiz Research finds a parallel compromise of kics-github-action, as Aqua relays it	[6]	Reported
24 Mar	Commission CSOC alerts on Amazon API misuse, possible account compromise and abnormal traffic; incident response begins	[1] [2]	Confirmed
24 Mar	Microsoft publishes detection guidance; at RSA, Mandiant's Charles Carmakal speaks of over 1,000 impacted SaaS environments	[10] [13]	Confirmed (Microsoft's detections); Reported (remarks)
25 Mar	Commission notifies CERT-EU, secures the AWS secret, disables the new access keys; the account's rights are revoked	[1]	Confirmed
26 Mar	CISA adds CVE-2026-33634 to KEV	[5]	Confirmed
27 Mar	Commission press release IP/26/748	[2]	Confirmed
27 Mar	An unnamed actor tells BleepingComputer it took over 350 GB and will leak, not extort	[14]	Reported
28 Mar	ShinyHunters publishes the dataset on its leak site	[1]	Confirmed (as CERT-EU states it)
30 Mar	GHSA last updated; BleepingComputer and Infosecurity Magazine report ShinyHunters' leak entry and its larger claims	[3] [15] [16]	Confirmed (GHSA); Reported (news)
31 Mar	Commission begins meetings with affected hosting clients	[1]	Confirmed
2 Apr	CERT-EU publishes its post-incident report	[1]	Confirmed

Date (2026)	Event	Source	Grade
27 Apr	Microsoft's update folds the Bitwarden CLI into the campaign	[10]	Reported
2 Jul	FBI FLASH-20260702-01 on TeamPCP	[8]	Confirmed
26 Aug	Two Western Australian men, 21 and 23, charged with 14 offences; the FBI calls them alleged TeamPCP members	[9]	Confirmed (as charges)
28 Aug	Risky Bulletin links the arrests to Trivy, KICS, LiteLLM and Telnyx	[17]	Reported

Two counts differ in the record. Aqua's advisory gives 76 of 77 trivy-action tags; some news and Aqua's own blog give 75 [3] [6] (**Confirmed** for the advisory figure). The actor's "over 350 GB" claim [14] sits close to CERT-EU's 340 GB uncompressed figure and far above its 91.7 GB compressed figure [1] (**Inferred** comparison).

Part 2: the intrusion record

Upstream: how Trivy was poisoned. The full upstream record, with the Checkmarx, LiteLLM, Telnyx and Bitwarden CLI publishes, is in the TeamPCP supply-chain study; this summary keeps only what the Commission case needs. In late February the attacker abused a misconfigured GitHub Actions environment in the Trivy project to extract a privileged access token [6] (**Confirmed**). Aqua disclosed the incident on 1 March and rotated credentials, but not atomically, so the attacker may have seen the refreshed tokens [3] [4] (**Confirmed**). On 19 March those credentials were used to push a malicious v0.69.4 tag and to repoint the trivy-action and setup-trivy tags [3] (**Confirmed**). Releases created after immutable releases were switched on (3 and 4 March) could not be moved, which is why v0.69.3 and trivy-action 0.35.0 stayed clean and why the deleted trivy-action tags were re-issued with a `v` prefix [3] (**Confirmed**). Images referenced by digest, source builds and the official Homebrew formula were not affected [3] (**Confirmed**).

What the stealer did. The injected code read the memory of the GitHub Actions `Runner.Worker` process, swept more than 50 locations on disk for SSH keys and for AWS, GCP, Azure, Kubernetes and Docker credentials, encrypted what it found with AES-256-CBC wrapped in RSA-4096, and sent it to a typosquatted domain, `scan[.]aquasecurtiy[.]org` [3] (**Confirmed**). If that failed, it fell back to creating a public `tpcp-docs` repository on the victim's own GitHub account [3] (**Confirmed**). The malware labels itself "TeamPCP Cloud stealer" [6] (**Confirmed** as Aqua's observation).

Downstream: inside the Commission's AWS estate. On 19 March the attacker held a Commission AWS API key. The same day it ran TruffleHog, an open-source secret scanner that checks AWS keys by calling STS, to look for more secrets, and began reconnaissance [1] (**Confirmed**). The key carried management rights over other Commission-affiliated AWS accounts. The attacker created a new access key and attached it to an existing user, which CERT-EU describes as an attempt to evade detection [1] (**Confirmed**). The compromised account is part of the backend of the europa.eu hosting service, and data were taken from it [1] (**Confirmed**). CERT-EU had uncovered no lateral movement as of 2 April, and no site was taken offline or altered [1] (**Confirmed**).

Containment. On 25 March the Commission secured the compromised secret and disabled the newly created keys, and it revoked the account's rights [1] (**Confirmed**; CERT-EU does not date the revocation). AWS told BleepingComputer its services "operated as designed" [14] and told Infosecurity they were not compromised

[16] (**Reported**).

Part 3: who and why

The record supports three distinct statements, and they should not be merged.

The Trivy compromise and TeamPCP. Aqua links the compromise to TeamPCP, also tracked as DeadCatx3, PCPcat and ShellForce, because the malware names itself and overlaps with earlier TeamPCP tooling. Aqua calls the attribution plausible but not confirmed, since the label could be a false flag [6] (**Reported** as attribution; **Confirmed** that Aqua states it). Aqua's advisory itself names no actor [3] (**Confirmed**). Microsoft attributes the campaign to "the threat actor identifying as TeamPCP" [10] (**Reported**). ATT&CK records G1056 TeamPCP as a financially motivated, cloud-native group active since at least September 2025, with associated names PCPCat, ShellForce, DeadCatx3, SHADOW-WATER-058 and UNC6780; its references do not name the Commission [11] (**Confirmed**).

The Commission intrusion. CERT-EU cites Aqua's public attribution of the Trivy compromise to TeamPCP but does not itself attribute the AWS intrusion to TeamPCP [1] (**Confirmed**). Its high-confidence finding is about the access vector, not the operator.

The leak and ShinyHunters. CERT-EU says ShinyHunters, a data extortion group, published the dataset on 28 March, and states no relationship between ShinyHunters and TeamPCP [1] (**Confirmed**). BleepingComputer reports that ShinyHunters claimed responsibility and released an archive of over 90 GB [15] (**Reported**). ATT&CK describes G1057 ShinyHunters as a criminal collective active since at least 2019 that gathers credentials and personal data for resale or extortion and is associated with The Com, whose members have included Scattered Spider (G1015) and LAPSUS$ (G1004) [12] [18] (**Confirmed**). At RSA, Wiz named Lapsus$ as working with the Trivy attackers [13] (**Reported**). No primary source opened shows how the data passed from the intruder to the leak site (**Inferred** from the absence).

Law enforcement. The FBI's July FLASH says TeamPCP modified Trivy, KICS, LiteLLM and the Telnyx Python SDK, engaged in extortion and collaboration with other groups, and published victim names on a leak site; it lists CVE-2026-33634 and names neither the Commission nor ShinyHunters [8] (**Confirmed**). On 26 August Australian police charged two Western Australian men, whom the FBI calls "allegedly members of the cybercriminal group TeamPCP" [9] (**Confirmed** as a statement of charges; guilt is not established). Mandiant's Charles Carmakal said the actors are mainly based in the US, UK, Canada and Western Europe [13] (**Reported**).

Motive. ATT&CK records TeamPCP as financially motivated [11] (**Confirmed**). The actor that spoke to BleepingComputer said it would leak the Commission data rather than extort [14] (**Reported**). Nothing in the record suggests the Commission was chosen; it ran an affected Trivy during the exposure window (**Inferred** from [1] [3]).

Part 4: impact and response

Victims and data. The victim system was the AWS backend of the europa.eu web hosting service, with up to 71 affected clients: 42 internal Commission clients and at least 29 other Union entities [1] (**Confirmed**). The published set was about 91.7 GB compressed and 340 GB uncompressed. It holds names, usernames and email addresses, mainly from Commission websites, plus at least 51,992 outbound email files (2.22 GB) whose bounce-backs may carry user-submitted content; database analysis was still under way on 2 April [1] (**Confirmed**). The Commission says the attack was contained without disrupting the websites and that internal systems were not affected [2] (**Confirmed**).

Larger claims. Infosecurity Magazine relayed a ShinyHunters claim, also recorded by CERT-EU [1], of more than 350 GB including mail server dumps, databases, confidential documents and contracts, and researchers at International Cyber Digest who claimed DKIM signing keys, internal admin URLs, NextCloud and Athena data and possibly an SSO user directory [16] (**Reported**, unverified by any primary source opened).

The regulatory chain. The Commission notified CERT-EU on 25 March under Article 21 of Regulation (EU, Euratom) 2023/2841, and CERT-EU supported the response under Article 22 [1] (**Confirmed**). The Commission notified its Data Protection Controller, the affected entities' data protection officers, and the European Data Protection Supervisor as Regulation (EU) 2018/1725 requires [1] (**Confirmed** as CERT-EU states it). The EDPS's own record was not checked. CERT-EU published its report in agreement with the Commission and in the interest of transparency [1] (**Confirmed**).

The campaign around it. Australian police estimate that the campaign's malicious code potentially compromised more than 1,000 organisations, enabled theft of more than 500,000 credentials and exfiltration of at least 300 GB, at a remediation cost of hundreds of millions of dollars [9] (**Confirmed** as police estimates, not counts). Socket counted over 10,000 workflow files referencing trivy-action [13] (**Reported**). Aqua says it cannot notify all Trivy users and found no sign its commercial products were affected [6] (**Confirmed**).

Context. The Commission disclosed an unrelated breach of its mobile device management platform in February 2026, discovered on 30 January and reportedly tied to Ivanti EPMM flaws [14] (**Reported**; primary not opened).

Part 5: the defender and vulnerability-management view

A KEV entry with no patch to apply. CVE-2026-33634 is CWE-506, embedded malicious code, so "remediation" means moving to a known-good version and rotating every secret the bad one could read [3] [4] [5] (**Confirmed**). A ticket closed on the upgrade alone leaves the stolen keys live (**Inferred**). Triage should start from the exposure windows in Part 1: a pipeline that ran trivy-action between 17:43 on 19 March and about 05:40 on 20 March is in scope even if it now runs a safe version [3] (**Confirmed** for the windows).

What the FBI and Microsoft add. The FBI adds runtime egress monitoring of runners, phishing-resistant MFA on publishing accounts, a minimum package age before adoption, and temporary rather than static credentials [8] (**Confirmed**). Microsoft lists detections including `Trojan:Linux/EntryPointStealer.BZ` and Defender for Cloud alerts for secret reconnaissance and TeamPCP commands, and recommends immutable releases, a least-privilege `GITHUB_TOKEN`, just-in-time secrets and ephemeral runners [10] (**Confirmed** as Microsoft's own products and guidance).

The decisive failures. Upstream, the non-atomic rotation after 1 March may have let the attacker keep access for 19 March; Aqua calls the 19 March attack a continuation [3] [4] (**Confirmed** as Aqua's assessment). Downstream, an AWS key with management rights over other Commission accounts was reachable from the pipeline that ran Trivy [1] (**Confirmed**); whether it was long-lived is not stated (**Inferred** risk). The CSOC's alerts on Amazon API misuse, possible account compromise and abnormal traffic started the response [1] (**Confirmed**). Pairing those three as the lesson is this study's reading (**Inferred**).

What is overstated and what is understated

- **Overstated: "ShinyHunters hacked the European Commission."** CERT-EU credits the access vector to the Trivy compromise and says only that ShinyHunters published the data [1] (**Confirmed**). The responsibility claim is news reporting of an actor's claim [15] (**Reported**).
- **Overstated: mail servers, contracts and an SSO directory.** These come from ShinyHunters' leak-site claim, which CERT-EU records but does not endorse [1], and from International Cyber Digest research relayed by Infosecurity [16] (**Reported**). CERT-EU's measured set is mostly website data and automated email [1] (**Confirmed**).
- **Understated: the reach of one pipeline key.** A single CI/CD secret carried management rights over several Commission AWS accounts [1] (**Confirmed**). That no lateral movement was found does not change what the key allowed (**Inferred**).
- **Understated: who was harmed.** The data may pertain to websites of up to 71 hosting clients, including at least 29 Union entities besides the Commission [1] (**Confirmed**); that makes at least 30 Union bodies (**Inferred**).
- **Understated: the vendor's first containment.** Aqua's 1 March rotation was incomplete, and its own discussion says so [3] [7] (**Confirmed**).
- **Understated: the record's rarity.** The Commission is the only downstream victim in the opened government record (CERT-EU, FBI, AFP) with a published post-incident report, and none of the FBI, AFP or Aqua primaries names it [1] [8] [9] [6] (**Inferred** from those sources).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND. Every id was checked against the library's data files (`data/attack/technique_profiles.jsonl`, `software_to_technique.jsonl`, `group_to_technique.jsonl`, `d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl`) and, for the groups, the live ATT&CK pages on 11 November 2026 [11] [12] [18]. CERT-EU published its own technique mapping [1]; rows beyond it are this study's mappings. ATT&CK v20.0 has no campaign object for this incident or for the Trivy compromise [11] [18]. The incident touches no industrial system, so there is no ATT&CK for ICS table.

ATT&CK Enterprise techniques

Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment.

The Commission intrusion

Id	Name	Tactic (v20.0)	Where it appears in the record	Source	Mapping
T1195.002	Compromise Software Supply Chain	Initial Access	Compromised Trivy received through normal update channels, 19 Mar	[1] [3]	CERT-EU
T1586.003	Cloud Accounts (Compromise Accounts)	Resource Development	Commission AWS secret obtained, 19 Mar	[1]	CERT-EU
T1078.004	Cloud Accounts (Valid Accounts)	Initial Access, Persistence, Privilege Escalation, Stealth	Stolen key used against the Europa hosting account, 19 to 25 Mar	[1]	CERT-EU
T1005	Data from Local System	Collection	Website data taken from the hosting backend, published 28 Mar	[1]	CERT-EU
T1098.001	Additional Cloud Credentials	Persistence, Privilege Escalation	New access key attached to an existing user, after 19 Mar (undated by CERT-EU)	[1]	Inferred
T1552.001	Credentials In Files	Credential Access	TruffleHog run to find further secrets, 19 Mar	[1]	Inferred
T1580	Cloud Infrastructure Discovery	Discovery	Reconnaissance after the key was obtained, 19 Mar	[1]	Inferred

The upstream Trivy compromise. Each row below describes behavior in Aqua's record. The "ATT&CK object" column names the G1056 or S9041 entry in ATT&CK v20.0 that lists the same technique [18] (**Confirmed** for the listing); tying the technique to the specific event is this study's reading (**Inferred**).

Id	Name	Tactic (v20.0)	Where it appears in the record	Source	ATT&CK object
T1677	Poisoned Pipeline Execution	Execution	Misconfigured Trivy GitHub Actions environment abused, late Feb	[6]	G1056
T1528	Steal Application Access Token	Credential Access	Privileged access token extracted, late Feb	[6]	G1056, S9041
T1195.001	Compromise Software Dependencies and Development Tools	Initial Access	Poisoned trivy-action and setup-trivy tags, 19 Mar	[3]	G1056
T1583.001	Domains	Resource Development	Typosquatted exfiltration domain, 19 Mar	[3]	G1056
T1003.007	Proc Filesystem	Credential Access	`Runner.Worker` process memory read, 19 Mar	[3]	S9041
T1552.004	Private Keys	Credential Access	SSH keys swept, 19 Mar	[3]	G1056, S9041
T1560.001	Archive via Utility	Collection	Haul encrypted with AES-256-CBC and RSA-4096 before exfiltration, 19 Mar	[3]	S9041
T1041	Exfiltration Over C2 Channel	Exfiltration	Data sent to attacker infrastructure, 19 Mar	[3]	S9041

Id	Name	Tactic (v20.0)	Where it appears in the record	Source	ATT&CK object
T1567.001	Exfiltration to Code Repository	Exfiltration	Fallback to a public `tpcp-docs` repository, 19 Mar	[3]	S9041
T1008	Fallback Channels	Command and Control	Same fallback path, 19 Mar	[3]	S9041

The T1552.001 row in the first table also covers the stealer's sweep of more than 50 credential locations [3], which ATT&CK lists for S9041 [18].

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to this incident	Source
TeamPCP	G1056	Attributed the Trivy compromise by Aqua (plausible); cited by CERT-EU; subject of the FBI FLASH and Australian charges. Not attributed the Commission intrusion by CERT-EU	[1] [6] [8] [9] [11]
ShinyHunters	G1057	Published the dataset, per CERT-EU; claimed responsibility, per news	[1] [12] [15]
LAPSUS$	G1004	Named by Wiz as working with the Trivy attackers; associated with The Com in the G1057 entry	[12] [13]
Scattered Spider	G1015	Named in the G1057 entry as a member of The Com; no direct tie to this incident	[12]
TeamPCP Cloud Stealer	S9041	The payload that names itself "TeamPCP Cloud stealer"; ATT&CK alias SANDCLOCK	[6] [11] [18]
CanisterWorm	S9042	Self-propagating npm worm using stolen publish tokens, documented by Aikido as Aqua relays it	[6] [11]
Mini Shai-Hulud	S9043	G1056 software; recorded in the library's npm study	[11] [19]

No ATT&CK campaign object covers the Trivy compromise or the Commission intrusion in v20.0 [11] [18].

CWE and CAPEC

Weakness	Name	Who assigns it	CAPEC in the library	Source
CWE-506	Embedded Malicious Code	GitHub advisory, NVD and KEV for CVE-2026-33634	CAPEC-442 Infected Software, CAPEC-448 Embed Virus into DLL and CAPEC-636 Hiding Malicious Data or Code within Files are the library's CAPEC entries related to CWE-506; CAPEC-442 fits this case, the other two less so (Inferred)	[3] [4] [5] [18]

The library also relates T1195.002 to CAPEC-186 Malicious Software Update and CAPEC-669 Alteration of a Software Update, which match a poisoned release served through normal update channels [18] (**Confirmed** for the data; **Inferred** for the fit). The CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Id	Library mappings to this study's techniques	Guidance it matches	Source
Software Update	D3-SU	T1195.001, T1195.002	Upgrade to a known-safe Trivy	[1] [18]
Software Inventory	D3-SWI	T1195.001, T1195.002	Audit Trivy versions in all environments	[1] [18]
Restore Software	D3-RS	T1195.001, T1195.002	Malicious artifacts removed and safe tags re-issued	[3] [7] [18]
Credential Revocation	D3-CR	T1098.001, T1528	New keys disabled and account rights revoked	[1] [18]
Credential Rotation	D3-CRO	T1098.001, T1528	Rotate every secret exposed to Trivy	[1] [8] [18]
Credential Compromise Scope Analysis	D3-CCSA	T1098.001, T1528	Treat all reachable secrets as exposed	[4] [18]
Administrative Network Activity Analysis	D3-ANAA	T1098.001	CloudTrail review for new keys and STS calls	[1] [18]
User Account Permissions	D3-UAP	T1078.004	Least-privilege CI/CD credentials and SCPs	[1] [18]
Access Modeling	D3-AM	T1078.004	Knowing which keys reach which accounts	[1] [18]
Multi-factor Authentication	D3-MFA	T1098.001, T1528	Phishing-resistant MFA on publishing accounts	[8] [18]
Outbound Traffic Filtering	D3-OTF	T1008, T1567.001	Runtime egress monitoring of runners	[8] [18]
Network Traffic Community Deviation	D3-NTCD	T1008, T1041, T1098.001, T1567.001	The abnormal-traffic alert that started the response	[1] [18]

The technique mappings in the third column are the library's `d3fend_countermeasures.jsonl` (**Confirmed** for the data [18]); pairing each countermeasure with the cited guidance is this study's reading (**Inferred**).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/european-commission-cloud-breach-2026.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by the strength of its tie to this record: 100 for CERT-EU's own mapping, 60 where Aqua's advisory states the behavior and the ATT&CK entry for G1056 or S9041 lists the technique, and 40 for this study's other Inferred mappings. Each entry's comment names the source numbers above.

Cross-cutting themes

- **Security tools are supply chain too.** A scanner runs with the pipeline's secrets by design. This compromise turned that trust into reach, as earlier trusted-update cases did; see SolarWinds SUNBURST and the XZ Utils backdoor (**Inferred** lineage).

- **Containment has to be atomic.** Aqua's first rotation was not atomic and may have left the attacker access, and Aqua treats the 19 March attack as its continuation [3] [4] (**Confirmed** as Aqua's assessment). Revoking everything at once, then reissuing, is the lesson (**Inferred**).
- **Mutable references are an attack surface.** Tags were moved, while images referenced by digest and releases created under immutable releases were not affected [3] (**Confirmed**). See Supply Chain Security Reference.
- **Cloud keys outlive the incident that leaked them.** The FBI's warning about affiliated actors reusing stolen credentials "long after" the compromise applies to every pipeline in the exposure window [8] (**Confirmed**). See Secrets Management.
- **One compromise, many victims, one leak site.** Like the Cl0p file-transfer campaigns, an upstream compromise fed public leak-site extortion across organisations (**Inferred** lineage). The worm lineage is in npm Supply-Chain Attacks and the LiteLLM thread in AI Threats 2026 [19] (**Confirmed** as the library records them); see also the Hugging Face supply chain study.
- **Attribution layers should stay separate.** Tool compromise, cloud intrusion and data leak have different evidence, and the sources keep them apart [1] [6] [15] (**Confirmed**). See Threat Actors.

Sources

All sources were opened on 11 November 2026. Grades apply to the source as used here.

#	Source	URL	Opened	Grade
1	CERT-EU, European Commission cloud breach: a supply-chain compromise, 2 Apr 2026	cert.europa.eu/blog/european-commission-cloud-breach-trivy-supply-chain	2026-11-11	Confirmed
2	European Commission, press release IP/26/748, Commission responds to cyber-attack on its Europa web platform, 27 Mar 2026 (print PDF)	ec.europa.eu/commission/presscorner/api/files/document/print/en/ip_26_748/IP_26_748_EN.pdf	2026-11-11	Confirmed
3	Aqua Security, GitHub advisory GHSA-69fq-xp46-6x23 (CVE-2026-33634), published 21 Mar 2026, updated 30 Mar 2026	github.com/aquasecurity/trivy/security/advisories/GHSA-69fq-xp46-6x23	2026-11-11	Confirmed
4	NIST NVD, CVE-2026-33634, published 23 Mar 2026	nvd.nist.gov/vuln/detail/CVE-2026-33634	2026-11-11	Confirmed
5	CISA, Known Exploited Vulnerabilities catalog, CVE-2026-33634, added 26 Mar 2026	cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-33634	2026-11-11	Confirmed
6	Aqua Security, Trivy supply chain attack: what you need to know, 22 Mar 2026, updated through 1 Apr 2026	aquasec.com/blog/trivy-supply-chain-attack-what-you-need-to-know/	2026-11-11	Confirmed (Aqua's own statements); Reported (attribution and third-party findings it relays)
7	Trivy project, discussion #10425, Trivy Security incident 2026-03-19, opened 20 Mar 2026	github.com/aquasecurity/trivy/discussions/10425	2026-11-11	Confirmed
8	FBI, FLASH-20260702-01, Cyber Criminal Group TeamPCP, 2 Jul 2026 (TLP:CLEAR)	ic3.gov/CSA/2026/260702.pdf	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
9	Australian Federal Police, FBI and WA Police, joint media release on two WA men charged, 27 Aug 2026	afp.gov.au/news-centre/media-release/two-wa-men-charged-...	2026-11-11	Confirmed (as charges)
10	Microsoft Security blog, guidance on detecting, investigating and defending against the Trivy supply chain compromise, 24 Mar 2026, updated 27 Apr 2026	microsoft.com/en-us/security/blog/2026/03/24/...	2026-11-11	Confirmed (Microsoft's detections and guidance); Reported (attribution)
11	MITRE ATT&CK, G1056 TeamPCP, created 16 Jul 2026, modified 2 Sep 2026	attack.mitre.org/groups/G1056/	2026-11-11	Confirmed
12	MITRE ATT&CK, G1057 ShinyHunters, created 29 Jul 2026	attack.mitre.org/groups/G1057/	2026-11-11	Confirmed
13	The Register, report on Mandiant, Wiz and Socket remarks about the Trivy compromise at RSA, 24 Mar 2026	theregister.com/2026/03/24/1k_cloud_environments_infected_following/	2026-11-11	Reported
14	BleepingComputer, report on the Commission investigating a breach of an Amazon cloud account, 27 Mar 2026	bleepingcomputer.com/news/security/european-commission-investigating-breach-...	2026-11-11	Reported
15	BleepingComputer, report on the Commission confirming the Europa.eu data breach, 30 Mar 2026	bleepingcomputer.com/news/security/european-commission-confirms-data-breach-...	2026-11-11	Reported
16	Infosecurity Magazine, European Commission Confirms Cloud Data Breach, 30 Mar 2026	infosecurity-magazine.com/news/european-commission-cloud-data/	2026-11-11	Reported
17	Risky Bulletin, report on two alleged TeamPCP members arrested in Australia, 28 Aug 2026	risky.biz/risky-bulletin-two-teampcp-members-arrested-in-australia/	2026-11-11	Reported
18	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `software_to_technique.jsonl`, `group_to_technique.jsonl`, `campaigns.jsonl`, `d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl` (ATT&CK v20.0)	github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-11	Confirmed
19	TeamStarWolf library case studies: AI Threats 2026 and npm Supply-Chain Attacks	github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies	2026-11-11	As graded in each study

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Threat Group Profiles, Malware Families, Notable Incidents
- Supply Chain Security, Supply Chain Security Reference, DevSecOps Reference, Secrets Management Reference
- Cloud Security Reference, Cloud Attack Reference, Identity and Access Management Reference, Incident Response Reference
- Vulnerability Management Reference, Vulnerability Prioritization Reference
- Case studies: The TeamPCP Supply-Chain Campaign of 2026, The Year 2026 in Intrusions, AI Threats 2026, npm Supply-Chain Attacks, SolarWinds SUNBURST, XZ Utils Backdoor, Cl0p File Transfer, Hugging Face Supply Chain; other ShinyHunters (G1057) studies: Oracle PeopleSoft and ShinyHunters 2026, Instructure Canvas Breach 2026
- Navigator layers, including this study's layer, european-commission-cloud-breach-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies